

Lab V.1 – Zero Trust QA Gap Analysis

Based on Labs III.2, III.4, III.5 and III.8

The supplied QA evidence shows that Zero Trust coverage is strongest around authentication, authorization and session enforcement, but weaker around continuous asset posture, dynamic context evaluation, secure-communication breadth and security telemetry. Lab III.2 contains 20 MFA/login cases with 16 passes and 4 failures. It directly exercises valid and invalid credentials, TOTP, recovery codes, account states, session timeout, concurrent login, logout and protected-resource access. These cases provide strong evidence for NIST Tenet 6 (dynamic authentication and authorization) and useful evidence for Tenet 3 (per-session access). The failures in OTP reuse, non-existent username handling, remember-device behavior and concurrent login should be retained as risk evidence rather than hidden. Lab III.4 adds API-level evidence for challenge generation, authenticated login, device retrieval, user details, TOTP status, token validation and logout. However, the Newman run was affected by an empty `base_url` configuration, so its repeated URI/assertion failures should not be interpreted automatically as product-security defects. Lab III.5 contains 50 automated functional UI cases, but the supplied scenarios do not directly assert Zero Trust controls; therefore they create little direct ZT coverage. Lab III.8 provides useful security-scanning evidence, including missing CSP, anti-clickjacking and HSTS headers, cookie-security issues and information disclosure. However, that scan targets OWASP Juice Shop, not InstaSafe, so it cannot be used as direct InstaSafe product evidence. The most critical gap is NIST Tenet 5: continuous measurement of asset integrity and security posture. The existing Get Devices and suspended-device tests do not prove that an unhealthy device is continuously assessed and that its posture changes the access decision. A high-priority new test should deliberately use a non-compliant device posture and verify that access is denied or restricted. Additional gaps exist in dynamic behavioral/environmental policy and telemetry feedback. The QA plan should therefore expand from authentication-focused testing toward continuous device posture, context-aware access decisions and security-event feedback into policy.

Recommended new scenario

Critical gap – Tenet 5: Use a test device that fails a defined security-posture requirement, request a protected MARS resource, and verify that the platform detects the non-compliant posture and blocks or restricts access. Restore compliant posture and verify that access is re-evaluated.

Coverage conclusion

Tenet	Coverage	Assessment
T1	Partial	Protected resources tested; complete resource inventory not demonstrated.
T2	Partial	HTTPS endpoints present; transport/location independence not comprehensively tested.
T3	Tested	Session timeout, concurrent login and logout/protected URL covered.
T4	Partial	Identity/device/account state covered; behavioral/environmental context missing.
T5	Not Tested	Continuous asset integrity/posture measurement not demonstrated.
T6	Tested	MFA, OTP, token, challenge and logout enforcement are strong.
T7	Not Tested	No direct telemetry-to-policy feedback test identified.

Evidence note: The ZAP scan is for OWASP Juice Shop and is intentionally treated as external security-testing evidence, not as direct InstaSafe evidence.